



UNIVERSIDAD PRIVADA DE TACNA
FACULTAD DE INGENIERÍA
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS
INFORME DE LABORATORIO N.º 03
AUDITORÍA DE SISTEMAS · SI-084
Evaluación de riesgos con SimpleRisk y detección técnica con Nuclei

Semana N.º 03 · Unidad I · Grupo N.º COLQUE

Integrantes

SERGIO COLQUE PONCE

Docente

Dr. Oscar Juan Jimenez Flores

Tacna, Perú



Índice

Actualice este índice en Word antes de exportar el PDF.

1. Información sobre el evento práctico

1.1 Título del evento práctico

Apreciación y tratamiento del riesgo de seguridad de la información sobre el entorno auditado, alimentada por evidencia técnica obtenida con Nuclei.

1.2 Objetivos

- Ejecutar un escaneo autorizado sobre el entorno si084-lab.
- Interpretar severidad técnica, CVE y exposición en función del contexto de negocio.
- Elaborar un registro con al menos diez riesgos y asignarles dueño, probabilidad e impacto.
- Definir tratamiento y controles de ISO/IEC 27001:2022 mediante un extracto de SoA.

1.3 Tiempo de duración

100 minutos: 60 de taller guiado y 40 de avance asistido.

1.4 Resultados de aprendizaje

RA2: Evalúa la seguridad de la información en Auditoría de Sistemas.

RA3: Aplica normas y estándares de auditoría para sustentar riesgos, controles y tratamiento.

1.5 Recursos

Recurso	Versión	Para qué se usó
Docker Desktop y Docker Compose	Cliente Docker 28.0.4	Ejecutar el entorno auditable y SimpleRisk
Nuclei	Imagen latest	Escaneo técnico autorizado como alternativa a Greenbone
Python	3.11	Conversión de reportes y construcción del registro de riesgos

1.6 Seguridad

El escaneo se limita a los contenedores del entorno local si084-lab. No se analizan sistemas institucionales, direcciones públicas ni equipos de terceros. Las aplicaciones vulnerables se publican únicamente en 127.0.0.1 y solo se emplean datos sintéticos.

2. Procedimiento o metodología

Se empleó como base el entorno Docker construido en el Taller 01. Para la detección técnica se seleccionó Nuclei, alternativa expresamente admitida por la guía cuando Greenbone/OpenVAS no es viable por consumo de recursos. Los resultados se sustentan en archivos técnicos y capturas fechadas.

Paso A — Preparar el entorno y el alcance autorizado

Se conservó el laboratorio de la Semana 01 y se documentó el alcance en 00_administracion/AUTORIZACION_ESCANEO_S03.md. Los únicos objetivos autorizados son juiceshop, dvwa y wordpress dentro de la red Docker si084-lab_audit_net.

Paso B — Desplegar y configurar SimpleRisk

Se añadieron los servicios `si084_srdb` y `si084_simplerisk` al archivo `entorno/docker-compose.yml`. La interfaz se publica exclusivamente en `http://127.0.0.1:8083`. La configuración de escalas 1–5 y el criterio de aceptación ≤ 6 se documentó en `PT03_escalas_riesgo.md`.

Las capturas 04 a 07 demuestran la operación, fórmula y apetito Medio (6); las capturas 08 a 15 demuestran el registro y tratamiento aceptado de R-001 a R-004.

Paso C — Ejecutar el escaneo técnico con Nuclei

El script `scripts/S03_ejecutar_escaneo.cmd` levanta el laboratorio, registra los contenedores y ejecuta Nuclei contra los tres servicios web internos. La salida JSONL se convierte de manera reproducible a CSV y XML mediante `scripts/S03_nuclei_a_reportes.py`.

El escaneo produjo tres hallazgos reales: métricas Prometheus expuestas, instalador de WordPress accesible y listado de archivos de configuración en DVWA. Se conservaron CSV, XML y JSONL.

Paso D — Convertir hallazgos técnicos en riesgos de negocio

El programa `30_papeles_trabajo/PT03_tecnico_a_riesgo.py` combina cada hallazgo con el dueño, clasificación, exposición y criticidad del activo. El registro final contiene diez riesgos: tres derivados de Nuclei y siete sustentados en la línea base de configuración del entorno.

Paso E — Tratamiento y extracto de la Declaración de Aplicabilidad

`PT03_soa_extracto.md` contiene cinco controles, incluido A.7.4 como control excluido y justificado, con referencias a los riesgos del registro. SimpleRisk conserva planes aceptados para R-001 a R-004.

3. Resultados

#	Resultado esperado	¿Se logró?	Evidencia
1	Greenbone/OpenVAS operativo o Nuclei como alternativa documentada	Logrado	Capturas 02–03 y E03_scan/
2	SimpleRisk configurado con escalas 1–5 y criterio de aceptación	Logrado	Capturas 04–07
3	Reporte técnico CSV y XML con objetivos autorizados	Logrado	20_evidencia/E03_scan/
4	Registro con al menos 10 riesgos	Logrado	40_hallazgos/PT03_registro_riesgos.csv
5	Dos casos contrastantes documentados	Parcial	R-003: CVSS alto/riesgo bajo; R-001: CVSS medio/riesgo alto
6	Cinco riesgos cargados y tratados en SimpleRisk	Parcial (4/5)	Capturas 08–15: R-001 a R-004
7	Extracto de SoA con cinco controles	Logrado	30_papeles_trabajo/PT03_soa_extracto.md



#	Resultado esperado	¿Se logró?	Evidencia
8	Hashes, cadena de custodia y commit	Pendiente	20_evidencia/SHA256SUMS_E03.txt

Se completó el escaneo con Nuclei, la configuración de SimpleRisk y el registro de diez riesgos. Se cargaron y trataron cuatro riesgos en SimpleRisk; el quinto quedó pendiente por límite de tiempo.

4. Conclusiones

1. El CVSS no sustituye la valoración de negocio: WordPress obtuvo severidad técnica crítica, pero riesgo Bajo (5) por el contexto del activo público. 2. La exposición de métricas y configuraciones demuestra que una respuesta HTTP exitosa puede revelar información suficiente para reconocimiento y ataques posteriores. 3. La gestión de secretos y el mínimo privilegio son prioritarios: las credenciales débiles y la cuenta erp_app con privilegios administrativos elevan el impacto sobre la base ERP restringida. 4. SimpleRisk permitió mantener trazabilidad entre activo, evidencia, dueño, valoración y tratamiento; quedó documentada la limitación de cuatro de cinco riesgos cargados por tiempo disponible.

5. Cuestionario

La guía del Taller 03 no presenta preguntas de cuestionario.

6. Referencias bibliográficas

ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. <https://www.iso.org/standard/27001> ISO/IEC 27002:2022. Information security controls. <https://www.iso.org/standard/75652.html> ISO/IEC 27005:2022. Guidance on managing information security risks. <https://www.iso.org/standard/80585.html> ISO 31000:2018. Risk management — Guidelines. <https://www.iso.org/standard/65694.html> ProjectDiscovery. Nuclei documentation. <https://docs.projectdiscovery.io/tools/nuclei>

7. Anexos

Anexo A — Reporte técnico de Nuclei en CSV, XML y JSONL. Anexo B — Registro PT03 con diez riesgos. Anexo C — Extracto de la Declaración de Aplicabilidad. Anexo D — Declaración firmada del alcance autorizado. Anexo E — Capturas 01 a 15 de ejecución, configuración y tratamiento. Repositorio: <https://github.com/srg-cp/SI084-LAB-01> Versión de entrega: <https://github.com/srg-cp/SI084-LAB-01/tree/taller-03>